**UNIVERSIDAD PRIVADA DE TACNA**
**FACULTAD DE INGENIERÍA**
**ESCUELA DE INGENIERÍA DE SISTEMAS**

# Guía Práctica de Laboratorio
# Semana 03

## "Guía de Laboratorio Nº 03 – Gestión de Activos y Riesgos de Seguridad de la Información"

**Que se presenta para el curso:**
**"Seguridad de Tecnologías de la Información"**

**AUTOR(ES):**

| | |
|---|---|
| **Erick Yoel Ayma Choque** | **(2021072616)** |
| **Dylan Yariet Tapia Vargas** | **(2021072630)** |
| **Hernandez Cruz Angel Gadiel** | **(2021070017)** |

**Docente:**
**Dr. Renzo Taco Coayla**

**TACNA – PERÚ**
**2026**

# Índice General


Introducción 3

Guía de Laboratorio Nº 03"Gestión de Activos y Riesgos de Seguridad de la Información" 4

1. Información sobre el evento práctico 4
   - 1.1. Título del evento práctico 4
   - 1.2. Objetivos 4
   - 1.3. Tiempo de duración (horas) 4
   - 1.4. Resultados de Aprendizaje (RA) 4
   - 1.5. Recursos (Equipos, materiales, programas y otros) 5
2. Procedimiento o Metodología 5
3. Conclusiones (especifique por lo menos 3) 16
4. Referencias Bibliográficas 17

# Introducción

La seguridad de la información constituye uno de los pilares fundamentales en la gestión moderna de las organizaciones del sector público y privado. En un entorno cada vez más digitalizado, donde los activos de información representan recursos estratégicos de alto valor, resulta imperativo implementar marcos de gestión que permitan identificar, clasificar y proteger dichos activos frente a amenazas y vulnerabilidades potenciales.

El presente laboratorio toma como sujeto de análisis a la SUNAT (Superintendencia Nacional de Aduanas y de Administración Tributaria), institución pública peruana que cuenta con un Plan Estratégico Institucional (PEI) 2024-2027 de acceso público, aprobado mediante Resolución de Superintendencia N.° 000068-2024/SUNAT. A partir de los objetivos estratégicos declarados en dicho plan, se identifican diez activos de información, se determina su criticidad, se calcula el nivel de riesgo aplicando la fórmula Riesgo = Probabilidad × Impacto, y se propone un plan de acción para mitigar los riesgos identificados.

# Guía de Laboratorio Nº 03 "Gestión de Activos y Riesgos de Seguridad de la Información"

## 1. Información sobre el evento práctico

### 1.1. Título del evento práctico

Gestión de Activos y Riesgos de Seguridad de la Información aplicada a la SUNAT

### 1.2. Objetivos

- Identificar y clasificar activos de información críticos y no críticos de la SUNAT a partir de su Plan Estratégico Institucional 2024-2027.
- Aplicar la metodología de cálculo de riesgo (Probabilidad × Impacto) sobre cada activo identificado, utilizando una escala del 1 al 10.
- Elaborar un plan de acción concreto para mitigar los riesgos detectados en los activos de mayor criticidad.

### 1.3. Tiempo de duración (horas)

4 horas académicas (200 minutos)

### 1.4. Resultados de Aprendizaje (RA)

RA1: Identifica y clasifica activos de información alineados al plan estratégico de una organización real.

RA2: Calcula el nivel de riesgo aplicando la fórmula Riesgo = Probabilidad × Impacto con escala del 1 al 10, clasificando los resultados en cuatro niveles.

RA3: Propone planes de acción concretos para la mitigación de riesgos de seguridad de la información.

### 1.5. Recursos (Equipos, materiales, programas y otros)

- Computadora con acceso a Internet
- Plan Estratégico Institucional (PEI) SUNAT 2024-2027 (disponible en https://www.sunat.gob.pe)
- Norma ISO/IEC 27001 como referencia metodológica
- Software de ofimática (procesador de texto, hoja de cálculo)

## 2. Procedimiento o Metodología

### 2.1. Empresa seleccionada: SUNAT

La Superintendencia Nacional de Aduanas y de Administración Tributaria (SUNAT) es el organismo técnico especializado del Estado peruano encargado de la administración de los tributos internos del Gobierno Nacional y de los derechos arancelarios derivados del comercio exterior. Su misión institucional, declarada expresamente en el PEI 2024-2027, es "servir al país a través de la administración justa, íntegra, eficaz y eficiente del sistema tributario y aduanero, necesaria para el desarrollo económico y social de los peruanos."

Es importante reconocer que la SUNAT es una institución con alta madurez en gestión de tecnologías de información. El propio PEI establece como indicador de la Acción Estratégica AEI 01.07 mantener la disponibilidad de sus servicios críticos en 99.80%, lo que implica la existencia de infraestructura redundante, monitoreo continuo y procedimientos de recuperación ante fallos. Asimismo, cuenta con una Intendencia Nacional de Sistemas de Información (INSI), una Oficina de Seguridad y Defensa Nacional (OSDENA) y está sujeta a auditorías del sistema de control interno. Esta realidad debe ser considerada al momento de evaluar probabilidades de riesgo.

### 2.2. Plan Estratégico Institucional (PEI) 2024-2027

El PEI 2024-2027 de la SUNAT establece cinco Objetivos Estratégicos Institucionales (OEI) que son la fuente directa para la identificación de activos de información:

OEI 01: Mejorar el cumplimiento tributario y aduanero de los administrados — medido mediante la Tasa Efectiva sobre Ventas del IGV (TIGV) y la Tasa Efectiva sobre Ingresos del Impuesto a la Renta de Tercera Categoría (TRTA).

OEI 02: Fortalecer la seguridad de la cadena logística en el comercio exterior — medido por el nivel de participación de OEA (Operadores Económicos Autorizados), con meta de 25% para 2024 y 31% para 2027.

OEI 03: Facilitar las operaciones lícitas en el comercio exterior — medido por el porcentaje de DAM de importación atendidas dentro de las 48 horas, con línea base de 72.3% y meta de 76.6% para 2027.

OEI 04: Fortalecer las capacidades de gestión institucional — medido por el porcentaje de cumplimiento de ejecución presupuestal anual, con meta de 95%.

OEI 05: Fortalecer la gestión del riesgo de desastres — medido por el porcentaje de cumplimiento de la implementación de la Gestión del Riesgo de Desastres (GRD), con meta de 100%.

Adicionalmente, el PEI declara cuatro políticas institucionales: acelerar la adopción de la gestión de riesgos de cumplimiento, acompañar iniciativas de productividad y desarrollo, impulsar la transformación digital y la innovación, y fortalecer la gestión interna y la rendición de cuentas.

### 2.3. Metodología de cálculo de riesgo

Se aplica la fórmula estándar:

**RIESGO RESIDUAL = PROBABILIDAD × IMPACTO**

Donde la probabilidad refleja la likelihood de que una amenaza se materialice considerando los controles ya existentes en la institución, y el impacto refleja la consecuencia real sobre la confidencialidad, integridad o disponibilidad del activo, reconociendo la capacidad de respuesta y contingencia de la SUNAT. Ambas variables se valoran en escala del 1 al 10.

Los cuatro niveles de riesgo son:

| Nivel | Puntuación | Descripción |
|---|---|---|
| BAJO | 1 – 25 | Riesgo residual tolerable con los controles actuales. |
| MODERADO | 26 – 50 | Riesgo que requiere monitoreo activo y mejoras puntuales. |
| ALTO | 50 – 75 | Riesgo significativo que requiere acción en el corto plazo. |
| CRÍTICO | 76 – 100 | Riesgo inaceptable que requiere acción inmediata. |

**GESTIÓN DE ACTIVOS**

**2.4. Identificación de los 10 Activos de Información de la SUNAT**

Los siguientes activos se derivan directamente de los objetivos estratégicos, acciones estratégicas e indicadores declarados en el PEI 2024-2027, así como de información pública del portal institucional de la SUNAT.

**ACTIVO A01 — Servicios Virtuales para Contribuyentes (Portal SOL y servicios en línea)** Tipo: Servicio digital / Sistema de información El PEI declara explícitamente la AEI 01.07 "Servicios Virtuales con disponibilidad garantizada para los administrados", cuyo indicador es el "Porcentaje de disponibilidad de los servicios críticos", con meta de 99.80% para todo el horizonte 2024-2027. Estos servicios incluyen los canales digitales mediante los cuales los contribuyentes presentan declaraciones, realizan pagos y consultan su situación tributaria. Son el punto de contacto digital principal entre la institución y sus administrados.

**ACTIVO A02 — Sistema de Declaraciones Aduaneras de Mercancías (DAM)** Tipo: Sistema de información / Proceso operativo El PEI declara en AEI 01.02 la gestión del cumplimiento aduanero medida por el "Porcentaje de DAM de importación para el consumo con diligencia de despacho" (meta 92.2% para 2024) y el "Porcentaje de DAM que cumplen con el pago oportuno" (meta 49.0%). Este sistema registra y tramita las declaraciones aduaneras que sustentan el comercio exterior del país.

**ACTIVO A03 — Sistema de Gestión de Riesgos de Cumplimiento Tributario** Tipo: Sistema de análisis / Proceso estratégico El PEI declara en AEI 01.03 la "Consolidación de la gestión de riesgos de cumplimiento tributario y aduanero de los administrados", con indicador de cumplimiento de entregables al 100% en todo el horizonte. Este activo corresponde al conjunto de modelos analíticos, bases de datos y procedimientos que la SUNAT usa para identificar riesgos de incumplimiento y orientar sus acciones de fiscalización.

**ACTIVO A04 — Plataforma de Modernización y Transformación Digital** Tipo: Infraestructura tecnológica / Programa institucional El PEI declara en AEI 01.04 la "Modernización y transformación digital de los procesos de la entidad", con indicadores de cumplimiento de entregables al 100% tanto en Tributos Internos como en Aduanas. Representa el conjunto de proyectos, sistemas y desarrollos tecnológicos en curso que sostienen la evolución digital de la institución.

**ACTIVO A05 — Sistema de Trazabilidad de Insumos Químicos y Bienes Fiscalizados (SICOBF)** Tipo: Sistema de información / Base de datos operativa El PEI declara en AEI 01.08 la "Trazabilidad ampliada de los insumos químicos y bienes fiscalizados en el país", con el indicador "Porcentaje de trazabilidad alcanzado en el control de insumos químicos con riesgo de desvío al tráfico ilícito de drogas (TID)", con meta entre 99.4% y 99.7% para todo el horizonte. El PEI menciona explícitamente el SICOBF como base de datos fuente del indicador.

**ACTIVO A06 — Sistema de Certificación de Operadores Económicos Autorizados (OEA)** Tipo: Proceso / Base de datos institucional El PEI declara en OEI 02 el objetivo de fortalecer la seguridad de la cadena logística medido por el "Nivel de participación de importadores y exportadores OEA", con meta de 31% del valor FOB para 2027. El programa OEA implica el registro, evaluación y certificación de operadores de comercio exterior, con datos sensibles de empresas exportadoras e importadoras.

**ACTIVO A07 — Sistema de Atención de Servicios TIC (Desarrollos Informáticos)** Tipo: Proceso / Sistema de gestión interna El PEI declara en AEI 04.01 la "Atención oportuna y eficaz de la demanda de servicios TIC de la institución", con el indicador de cobertura que considera los desarrollos informáticos atendidos y los acuerdos de niveles de servicio cumplidos, con meta de 60% para 2025, 70% para 2026 y 80% para 2027. Este activo corresponde a la gestión interna de los requerimientos tecnológicos de todas las unidades de la SUNAT.

**ACTIVO A08 — Sistema de Gestión del Riesgo de Desastres (GRD)** Tipo: Proceso / Documentación de continuidad El PEI declara en OEI 05 y AEI 05.01 la gestión eficaz de los procesos de riesgo de desastres, bajo la responsabilidad de la Oficina de Seguridad y Defensa Nacional (OSDENA), con meta de 100% de cumplimiento de entregables. Comprende los planes de continuidad, procedimientos de respuesta ante desastres y la documentación de los procesos de estimación, prevención y reducción del riesgo.

**ACTIVO A09 — Sistema de Ejecución Presupuestal (SIAF / SIGA)** Tipo: Sistema administrativo / Base de datos financiera El PEI declara en OEI 04 el indicador "Porcentaje de cumplimiento de la ejecución presupuestal anual a nivel pliego", con meta de 95% para todo el horizonte 2024-2027, y menciona explícitamente el SIAF (Sistema Integrado de Administración Financiera) y el SIGA (Sistema Integrado de Gestión Administrativa) como fuentes de información del indicador. Gestiona el presupuesto institucional de la SUNAT.

**ACTIVO A10 — Sistemas Administrativos y Funcionales Internos (ERP de RRHH y Administración)** Tipo: Sistema de gestión interna El PEI declara en AEI 04.02 la "Gestión eficiente de los sistemas administrativos y funcionales", bajo la responsabilidad de la Intendencia Nacional de Administración (INA), la Intendencia Nacional de Recursos Humanos (INRH) y la Intendencia Nacional de Formulación de Inversiones y Finanzas (INFIF), con indicador de cumplimiento de entregables al 100%. Comprende los sistemas de gestión de personal, administración y finanzas internas de la institución.

## 2.5. Clasificación de Activos: Críticos y No Críticos

**Criterio de clasificación:** Se considera CRÍTICO un activo cuya afectación en confidencialidad, integridad o disponibilidad paralizaría de forma inmediata y sin posibilidad de contingencia la operación esencial de la SUNAT, o generaría un daño legal, económico o reputacional catastrófico e irrecuperable

en el corto plazo, considerando que la institución ya cuenta con mecanismos de respaldo y contingencia.

Se considera NO CRÍTICO un activo cuya afectación, aunque indeseable, puede gestionarse mediante procedimientos alternativos, sistemas de respaldo o acciones correctivas sin comprometer la continuidad del servicio principal.

**A01 — Servicios Virtuales para Contribuyentes → CRÍTICO** El PEI lo eleva explícitamente como acción estratégica independiente (AEI 01.07) con un indicador propio de disponibilidad del 99.80%. Su interrupción prolongada impediría directamente la presentación de declaraciones y pagos en línea, afectando la recaudación tributaria. Si bien existen canales presenciales de contingencia, estos tienen capacidad limitada para absorber el volumen digital actual. Es el activo de cara al ciudadano más visible y sensible de la institución.

**A02 — Sistema de Declaraciones Aduaneras (DAM) → CRÍTICO** El PEI establece metas específicas de diligencia de despacho (92.2%) y pago oportuno (49.0%). Una interrupción o manipulación del sistema de DAM detendría el despacho de mercancías en los principales puertos y aeropuertos del país, generando pérdidas económicas directas al Estado y a los operadores de comercio exterior, sin posibilidad de contingencia manual para los volúmenes que maneja la institución.

**A03 — Sistema de Gestión de Riesgos de Cumplimiento Tributario → CRÍTICO** El PEI lo posiciona como una de las acciones estratégicas de mayor prioridad (AEI 01.03), articulada directamente con el OEI 01 que mide el cumplimiento tributario nacional. Una fuga o manipulación de los modelos de riesgo revelaría los criterios de selección de contribuyentes para fiscalización, permitiendo a grandes evasores anticipar y eludir las acciones de control. El daño no sería inmediato en la operación diaria, pero sí catastrófico para la efectividad del sistema tributario en el mediano plazo.

**A04 — Plataforma de Modernización y Transformación Digital → NO CRÍTICO** Aunque el PEI le asigna alta prioridad estratégica (AEI 01.04), un retraso o interrupción en los proyectos de transformación digital no paraliza las operaciones actuales de la SUNAT. Los sistemas existentes continúan funcionando; el impacto sería en el avance de los objetivos futuros, no en la operación del día a día. Es un activo estratégico de largo plazo, no un activo operativo crítico.

**A05 — Sistema SICOBF (Trazabilidad de Insumos Químicos) → CRÍTICO** El PEI declara una meta de trazabilidad entre 99.4% y 99.7% y establece su vinculación directa con la lucha contra el tráfico ilícito de drogas, coordinada con DEVIDA. Una falla en la integridad de este sistema permitiría el desvío de insumos químicos hacia actividades ilícitas sin detección oportuna, con consecuencias graves en materia de seguridad nacional y compromisos internacionales del Estado peruano.

**A06 — Sistema de Certificación OEA → NO CRÍTICO** Aunque el OEI 02 del PEI establece metas de crecimiento del programa OEA (de 24% a 31% del valor FOB al 2027), una afectación a este sistema no paralizaría las operaciones

aduaneras generales. El despacho de mercancías puede continuar por canales ordinarios. El impacto sería en la competitividad y confianza del programa, pero no en la operación esencial de la SUNAT.

**A07 — Sistema de Atención de Servicios TIC → NO CRÍTICO** El PEI reconoce que su indicador recién se implementará con metas desde 2025, y que en 2024 aún se está determinando la línea base. Una afectación a la gestión interna de requerimientos TIC impacta la eficiencia operativa interna, pero no la prestación directa de servicios tributarios o aduaneros a los administrados.

**A08 — Sistema de Gestión del Riesgo de Desastres (GRD) → CRÍTICO** El PEI asigna a la OSDENA la responsabilidad de los procesos de estimación, prevención, reducción y preparación ante desastres, con una meta de 100% de cumplimiento. Este activo —compuesto por los planes, procedimientos y documentación de continuidad— es crítico porque su degradación o pérdida dejaría a la institución sin capacidad de respuesta organizada ante un evento de continuidad, afectando indirectamente todos los servicios críticos del punto A01 en adelante.

**A09 — Sistema de Ejecución Presupuestal (SIAF/SIGA) → NO CRÍTICO** El SIAF es administrado por el Ministerio de Economía y Finanzas, no por la SUNAT, por lo que la institución tiene control limitado sobre su disponibilidad. Una afectación del SIGA interno impacta el seguimiento del gasto, pero la ejecución presupuestal puede continuar con registros alternativos. El PEI lo clasifica como un indicador de gestión interna (OEI 04, Tipo II), es decir, de soporte, no misional.

**A10 — Sistemas Administrativos Internos (RRHH, Administración, Finanzas) → NO CRÍTICO** Bajo la responsabilidad de la SNAAF según el PEI (AEI 04.02), estos sistemas gestionan procesos de soporte. Una afectación temporal puede gestionarse con procedimientos manuales de contingencia sin detener la operación tributaria o aduanera. El PEI los clasifica expresamente como OEI Tipo II (soporte y gestión interna), distintos de los objetivos misionales.

## GESTIÓN DE RIESGO

### 2.6 Matriz de Riesgo — Cálculo: Probabilidad × Impacto

**Nota metodológica importante:** Los valores de probabilidad asignados a continuación son probabilidades residuales, es decir, consideran que la SUNAT ya cuenta con controles de seguridad establecidos, monitoreo de sistemas, personal especializado en la INSI, auditorías internas del OCI y una infraestructura diseñada para alta disponibilidad. No se evalúa la amenaza en abstracto, sino la probabilidad de que dicha amenaza se materialice exitosamente dado el contexto real de la institución.

**ACTIVO A01 — Servicios Virtuales para Contribuyentes** Amenaza residual: Degradación del servicio por pico de demanda no previsto en fechas de vencimiento tributario o por falla puntual de algún componente de la cadena de servicio. Probabilidad: 4 — La SUNAT mantiene una meta de 99.80% de disponibilidad y cuenta con infraestructura de alta disponibilidad. Sin embargo, los picos de demanda en fechas críticas (vencimiento de PDT, IGV mensual) pueden generar degradación puntual de rendimiento no necesariamente cubierta por los controles actuales. Es un riesgo residual real pero de probabilidad baja-media dado los controles. Impacto: 8 — Una interrupción durante fechas de vencimiento afecta directamente la recaudación diaria y genera contingencias legales para los contribuyentes que no pueden declarar. El daño reputacional es alto aunque recuperable en horas. Riesgo = 4 × 8 = **32 → Nivel: MODERADO**

**ACTIVO A02 — Sistema de Declaraciones Aduaneras (DAM)** Amenaza residual: Errores de integridad en el registro de DAM por fallas en la integración con sistemas externos de operadores de comercio, o manipulación de datos en canales de interfaz con agentes de aduana. Probabilidad: 3 — El sistema de despacho aduanero tiene procesos formales de validación y la SUNAT cuenta con control aduanero especializado (INDIA, INCA). La probabilidad de una falla de integridad masiva es baja dado los controles de validación declarados en el PEI. Impacto: 8 — Una interrupción o corrupción de datos en el sistema DAM detendría el despacho de mercancías en puertos y aeropuertos, con impacto económico directo para el Estado y los operadores. Recuperable en días pero con costos significativos. Riesgo = 3 × 8 = **24 → Nivel: BAJO**

**ACTIVO A03 — Sistema de Gestión de Riesgos de Cumplimiento Tributario** Amenaza residual: Acceso no autorizado por un insider con privilegios elevados que exfiltre los modelos y criterios de selección de contribuyentes para fiscalización. Probabilidad: 3 — El acceso a este sistema está restringido a unidades especializadas (INER, INGP). La probabilidad de un insider threat que comprometa los modelos analíticos es real pero baja, dado que la SUNAT tiene controles de acceso diferenciados y auditorías de uso de sistemas. Impacto: 7 — La exposición de los modelos de riesgo no paralizaría operaciones inmediatas, pero reduciría la efectividad de la fiscalización en el mediano plazo al permitir que contribuyentes informen manipulen sus patrones de comportamiento para evitar ser seleccionados. Riesgo = 3 × 7 = **21 → Nivel: BAJO**

**ACTIVO A04 — Plataforma de Modernización y Transformación Digital** Amenaza residual: Retrasos o incumplimientos en los entregables de transformación digital por vulnerabilidades en la cadena de suministro de software (proveedores externos). Probabilidad: 5 — El PEI declara la dependencia de proveedores externos para los proyectos de transformación digital (AEI 01.04), y la gestión de terceros en proyectos tecnológicos representa un riesgo de cadena de suministro moderado en cualquier organización de este tamaño. Impacto: 5 — Un incumplimiento de entregables retrasa los objetivos estratégicos de 2024-2027 pero no afecta la operación actual. El impacto es estratégico, no operativo inmediato. Riesgo = 5 × 5 = **25 → Nivel: BAJO**

**ACTIVO A05 — Sistema SICOBF (Trazabilidad de Insumos Químicos)** Amenaza residual: Manipulación o corrupción de datos declarados por usuarios del sistema (empresas que reportan sus stocks de insumos químicos), generando inconsistencias en la trazabilidad. Probabilidad: 4 — El PEI reconoce explícitamente esta limitación al declarar que "se dificultará la medición del indicador si no existe un adecuado nivel de calidad y falta de disponibilidad de los datos del registro diario de operaciones presentados por los usuarios." Es un riesgo reconocido por la propia institución. Impacto: 7 — Inconsistencias en la trazabilidad podrían permitir el desvío de insumos hacia actividades ilícitas sin detección oportuna, con implicancias en seguridad nacional y compromisos con organismos internacionales. Riesgo = 4 × 7 = **28 → Nivel: MODERADO**

**ACTIVO A06 — Sistema de Certificación OEA** Amenaza residual: Falsificación o adulteración de documentación presentada por operadores para obtener la certificación OEA, aprovechando brechas en el proceso de verificación. Probabilidad: 3 — El proceso de certificación OEA implica evaluaciones formales y la participación de la INDIA e INCA. La probabilidad de que una empresa obtenga certificación con documentación fraudulenta es baja dado los controles existentes. Impacto: 6 — Un operador certificado fraudulentamente tendría beneficios en términos de plazos de despacho, pero el impacto institucional está acotado al programa OEA y no afecta la operación general de comercio exterior. Riesgo = 3 × 6 = **18 → Nivel: BAJO**

**ACTIVO A07 — Sistema de Atención de Servicios TIC** Amenaza residual: Priorización inadecuada de requerimientos tecnológicos críticos frente a no críticos, generando retrasos en el desarrollo de sistemas que soportan los OEI misionales. Probabilidad: 5 — El PEI reconoce que el indicador de cobertura TIC recién tendrá línea base en 2024 y metas desde 2025, lo que indica que la gestión de la demanda tecnológica aún está en proceso de maduración. La probabilidad de una priorización subóptima es moderada. Impacto: 4 — Un retraso en la atención de requerimientos TIC impacta la eficiencia interna pero raramente detiene servicios ya operativos. El impacto es indirecto y de mediano plazo. Riesgo = 5 × 4 = **20 → Nivel: BAJO**

**ACTIVO A08 — Sistema de Gestión del Riesgo de Desastres (GRD)** Amenaza residual: Planes de continuidad desactualizados o no probados que no reflejen la arquitectura actual de sistemas, dejando brechas en la respuesta ante un evento de desastre. Probabilidad: 4 — El PEI establece como meta el 100% de cumplimiento de implementación de la GRD, gestionada por la OSDENA. Sin embargo, la actualización continua de los planes frente a la evolución tecnológica de la institución representa un riesgo residual real en cualquier organización de este tamaño y complejidad. Impacto: 7 — Planes desactualizados no paralizan la operación normal, pero en caso de un evento real de desastre (sismo, incendio en el data center, inundación en sedes regionales), la respuesta sin planes actualizados podría prolongar significativamente el tiempo de recuperación, afectando todos los servicios críticos. Riesgo = 4 × 7 = **28 → Nivel: MODERADO**

**ACTIVO A09 — Sistema de Ejecución Presupuestal (SIAF/SIGA)** Amenaza residual: Errores en el registro de ejecución presupuestal por uso inadecuado del SIGA interno, generando inconsistencias entre el gasto

registrado y el ejecutado realmente, afectando el indicador de OEI 04. Probabilidad: 3 — El SIAF es un sistema del MEF con controles establecidos. El SIGA interno tiene usuarios capacitados. La probabilidad de error sistemático es baja dado los controles de conciliación periódica. Impacto: 5 — Un error en el registro presupuestal afecta la medición del OEI 04 y podría generar observaciones de auditoría, pero no paraliza la operación tributaria o aduanera. El impacto es administrativo y de gestión interna. Riesgo = 3 × 5 = **15 → Nivel: BAJO**

**ACTIVO A10 — Sistemas Administrativos Internos (RRHH, Administración, Finanzas)** Amenaza residual: Interrupción temporal de los sistemas de gestión de personal o administración por falla técnica, afectando procesos como el pago de planilla o la gestión de contratos. Probabilidad: 3 — Estos sistemas tienen respaldo por parte de la INA, INRH e INFIF, con procedimientos alternativos documentados. La probabilidad de una interrupción prolongada sin contingencia es baja. Impacto: 4 — Una falla temporal en sistemas administrativos impacta la gestión interna pero no compromete los servicios externos de la SUNAT. El daño es gestionable y temporal. Riesgo = 3 × 4 = **12 → Nivel: BAJO**

### 2.7. Resumen de la Matriz de Riesgo

| ID | Activo | Clasificación | Probabilidad | Impacto | Riesgo | Nivel |
|---|---|---|---|---|---|---|
| A01 | Servicios Virtuales para Contribuyentes | CRÍTICO | 4 | 8 | 32 | MODERADO |
| A02 | Sistema de Declaraciones Aduaneras (DAM) | CRÍTICO | 3 | 8 | 24 | BAJO |
| A03 | Sistema de Gestión de Riesgos de Cumplimiento | CRÍTICO | 3 | 7 | 21 | BAJO |
| A04 | Plataforma de Transformación Digital | NO CRÍTICO | 5 | 5 | 25 | BAJO |

| | | | | | | |
|---|---|---|---|---|---|---|
| A05 | Sistema SICOBF (Trazabilidad IQBF) | CRÍTICO | 4 | 7 | 28 | MODERADO |
| A06 | Sistema de Certificación OEA | NO CRÍTICO | 3 | 6 | 18 | BAJO |
| A07 | Sistema de Atención de Servicios TIC | NO CRÍTICO | 5 | 4 | 20 | BAJO |
| A08 | Sistema de Gestión del Riesgo de Desastres | CRÍTICO | 4 | 7 | 28 | MODERADO |
| A09 | Sistema de Ejecución Presupuestal (SIAF/SIGA) | NO CRÍTICO | 3 | 5 | 15 | BAJO |
| A10 | Sistemas Administrativos Internos | NO CRÍTICO | 3 | 4 | 12 | BAJO |

**Interpretación del resultado general:** El perfil de riesgo de la SUNAT, evaluado con criterio realista, muestra que la mayoría de los activos se encuentran en nivel BAJO de riesgo residual, lo que es consistente con el nivel de madurez de una institución que cuenta con infraestructura de alta disponibilidad, personal especializado y controles establecidos. Los tres activos en nivel MODERADO (A01, A05, A08) representan las brechas residuales más relevantes y merecen atención prioritaria. Ningún activo alcanza el nivel CRÍTICO ni ALTO, lo que refuerza que los controles existentes de la SUNAT son efectivos en su conjunto.

### 2.8. Plan de Acción

El plan de acción se orienta exclusivamente a los riesgos residuales identificados. Se evita proponer controles que el PEI o la infraestructura conocida de la SUNAT ya contemplan (como backups, monitoreo de disponibilidad o auditorías de control interno), enfocándose en las brechas específicas detectadas en la evaluación.

**A01 — Servicios Virtuales para Contribuyentes | Riesgo 32 — MODERADO**

Brecha identificada: La meta de 99.80% de disponibilidad está declarada en el PEI, pero la degradación de rendimiento en picos de demanda (no necesariamente una caída total) representa un riesgo residual no completamente cubierto por los indicadores actuales, que solo miden disponibilidad binaria y no calidad del servicio bajo carga.

Acción específica 1: Complementar el indicador de disponibilidad actual (AEI 01.07) con un indicador de tiempo de respuesta bajo carga pico, estableciendo un umbral de respuesta máximo aceptable en fechas de vencimiento tributario. Esto permitiría detectar degradación de rendimiento antes de que se convierta en una interrupción total.

Acción específica 2: Establecer simulacros de carga anuales programados que repliquen el volumen de las tres fechas de mayor demanda del año fiscal, con documentación de los resultados y ajustes de capacidad correspondientes.

Responsable: INSI — Gerencia de Operaciones y Soporte a Usuarios Plazo: 6 meses Vinculación PEI: AEI 01.07

**A05 — Sistema SICOBF | Riesgo 28 — MODERADO**

Brecha identificada: El propio PEI reconoce en la ficha técnica del indicador de AEI 01.08 que "se dificultará la medición del indicador si no existe un adecuado nivel de calidad y falta de disponibilidad de los datos del registro diario de operaciones presentados por los usuarios." Esta limitación declarada indica una brecha de integridad de datos dependiente de terceros que no está completamente controlada.

Acción específica 1: Implementar validaciones automáticas de consistencia en el SICOBF que detecten en tiempo real las declaraciones de usuarios con variaciones estadísticamente anómalas respecto a su histórico de operaciones, generando alertas automáticas para revisión por la Gerencia de Fiscalización de Bienes Fiscalizados (GFBF) antes de que afecten el cálculo del indicador.

Acción específica 2: Establecer un protocolo formal de gestión de "declaraciones con porcentaje negativo" (mencionadas en las especificaciones técnicas del indicador), documentando criterios claros para su exclusión o corrección, reduciendo la discrecionalidad en el proceso y mejorando la reproducibilidad de los cálculos.

Responsable: INIQBF — Intendencia Nacional de Insumos Químicos y Bienes Fiscalizados Plazo: 4 meses Vinculación PEI: AEI 01.08

**A08 — Sistema de Gestión del Riesgo de Desastres | Riesgo 28 — MODERADO**

Brecha identificada: El indicador del OEI 05 mide el porcentaje de cumplimiento de la implementación de la GRD (100% como meta), pero no incluye ningún indicador de prueba o ejercicio de los planes, solo de su elaboración y presentación de informes. Un plan no probado no garantiza su efectividad ante un evento real.

Acción específica 1: Incorporar al Programa de Actividades Anual de la GRD (gestionado por la OSDENA) al menos un ejercicio de simulacro de continuidad operativa por año que involucre a las unidades responsables de los activos A01 y A02, documentando tiempos de recuperación reales y comparándolos con los tiempos objetivos declarados en los planes.

Acción específica 2: Establecer un proceso semestral de revisión y actualización de los planes de continuidad ante cambios en la arquitectura tecnológica de la institución, vinculado al proceso de seguimiento del AEI 04.01 (servicios TIC), de modo que cualquier nuevo sistema incorporado a producción quede inmediatamente incluido en los planes de recuperación.

Responsable: OSDENA en coordinación con INSI Plazo: 8 meses Vinculación PEI: OEI 05 / AEI 05.01

**Activos con nivel BAJO (A02, A03, A04, A06, A07, A09, A10):**

Para los activos que resultaron con riesgo BAJO, no se propone un plan de acción correctivo sino de mantenimiento. La recomendación es que la INSI y las unidades responsables continúen el seguimiento periódico de los indicadores declarados en el PEI y que los controles existentes sean revisados anualmente como parte del ciclo normal de gestión de la SUNAT, sin necesidad de inversión adicional inmediata. El riesgo residual en estos activos es aceptable dado el nivel de madurez de la institución.

## 3. Conclusiones (especifique por lo menos 3)

- Primera conclusión: Cuando la evaluación de riesgos se realiza con criterio realista, reconociendo los controles existentes de una institución madura como la SUNAT, los riesgos residuales resultan significativamente menores a los que una evaluación teórica podría sugerir. De los diez activos analizados, ninguno alcanzó nivel CRÍTICO ni ALTO, y siete de diez se ubican en nivel BAJO. Esto demuestra que una gestión de seguridad efectiva no elimina los riesgos, pero los reduce a niveles residuales tolerables o moderados, que es precisamente el objetivo de un sistema de gestión de seguridad de la información.
- Segunda conclusión: La principal fortaleza del PEI 2024-2027 de la SUNAT en materia de seguridad de la información es la declaración explícita de indicadores medibles para sus activos más críticos, como la meta de 99.80% de disponibilidad para los servicios virtuales (AEI 01.07) o la meta de 99.4-99.7% de trazabilidad del SICOBF (AEI 01.08). Esta cultura de medición es en sí misma un control de seguridad, pues obliga a la

institución a detectar y reportar desviaciones. La brecha identificada es que los indicadores actuales miden resultado final, pero no incorporan métricas de calidad bajo condiciones de estrés ni de efectividad de los planes de continuidad.

- Tercera conclusión: Los tres activos que alcanzaron nivel MODERADO (Servicios Virtuales, SICOBF y GRD) tienen en común que su riesgo residual proviene de factores externos o de brechas en la medición, no de ausencia de controles técnicos. En A01, el riesgo proviene del comportamiento de la demanda en picos; en A05, de la calidad de los datos declarados por terceros; en A08, de la falta de pruebas de los planes de continuidad. Esto sugiere que la SUNAT debería orientar sus esfuerzos de mejora en seguridad hacia la gestión de riesgos de terceros y la validación práctica de sus planes, más que hacia la incorporación de nuevos controles técnicos internos.

## 4. Referencias Bibliográficas

SUNAT. (2024). Plan Estratégico Institucional (PEI) 2024-2027. Superintendencia Nacional de Aduanas y de Administración Tributaria. Aprobado mediante Resolución de Superintendencia N.° 000068-2024/SUNAT, marzo de 2024. Recuperado de https://www.sunat.gob.pe/legislacion/superin/2024/anexo-000068-2024.pdf

CEPLAN. (2017). Guía para el Planeamiento Institucional. Centro Nacional de Planeamiento Estratégico. Aprobada por Resolución de Presidencia de Consejo Directivo N.º 033-2017/CEPLAN/PCD y modificatorias.

CEPLAN. (2023). Guía para la elaboración de indicadores de políticas nacionales y planes estratégicos. Aprobada por Resolución de Presidencia de Consejo Directivo N.º 103-2023/CEPLAN/PCD.

ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. International Organization for Standardization.

ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks. International Organization for Standardization.

Gobierno del Perú. (2023). Decreto Supremo N.° 042-2023-PCM. Política General de Gobierno (PGG). El Peruano.